

Digital Policy Office

INFORMATION SECURITY

Practice Guide for Mitigation Strategy for Distributed Denial-of-Service Attacks

Version 1.1

July 2024

© The Government of the Hong Kong Special Administrative Region
of the People's Republic of China

The contents of this document remain the property of and may not be reproduced in whole or in part without the express permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China.
--

COPYRIGHT NOTICE

© 2024 by the Government of the Hong Kong Special Administrative Region of the People's Republic of China

Unless otherwise indicated, the copyright in the works contained in this publication is owned by the Government of the Hong Kong Special Administrative Region of the People's Republic of China. You may generally copy and distribute these materials in any format or medium provided the following conditions are met –

- (a) the particular item has not been specifically indicated to be excluded and is therefore not to be copied or distributed;
- (b) the copying is not done for the purpose of creating copies for sale;
- (c) the materials must be reproduced accurately and must not be used in a misleading context; and
- (d) the copies shall be accompanied by the words “copied/distributed with the permission of the Government of the Hong Kong Special Administrative Region of the People's Republic of China. All rights reserved.”

If you wish to make copies for purposes other than that permitted above, you should seek permission by contacting the Digital Policy Office.

Amendment History				
Change Number	Revision Description	Pages Affected	Revision Number	Date
1	Change “Office of the Government Chief Information Officer” (or “OGCIO”) to “Digital Policy Office” (or “DPO”)		1.1	July 2024

Table of Contents

1.	Introduction.....	1
1.1	Purpose.....	1
1.2	Normative References.....	1
1.3	Terms and Convention.....	1
1.4	Contacts.....	2
2.	Why you need a mitigation strategy for DDoS attacks?	3
3.	What are DDoS attacks?	4
4.	What are the mitigating measures?	7
5.	What anti-DDoS solutions are currently available?.....	10
6.	What you need to consider when deploying anti-DDoS solutions?	12

1. Introduction

Distributed denial-of-service (DDoS) attacks have emerged as one of the most significant and prevalent threats on the security landscape. Any systems with exposure to the Internet are vulnerable to DDoS attacks. DDoS attacks could disruptively cost the victims in loss of services, productivity, revenue and reputation. Government bureaux/departments (B/Ds) need a mitigation strategy for DDoS attacks in order to bolster defenses and reduce the risk of attack. This document serves as a quick reference guide for B/Ds when considering to formulate and develop a DDoS mitigation strategy.

1.1 Purpose

This Practice Guide outline a list of DDoS mitigating measures, introduces common anti-DDoS solutions available in the market, provides some considerations for deploying anti-DDoS solutions, and highlights some examples of anti-DDoS solutions.

1.2 Normative References

The following reference documents are indispensable for the application of this document.

For more information on the anti-DDoS solutions, please refer to the Catalogue of IT Security Solutions (CoSS) (<https://itginfo.ccgo.hksarg/content/coss/category/ads>).

1.3 Terms and Convention

For the purposes of this document, the terms and convention given in S17, G3, and the following apply.

Abbreviation and Terms	
B/Ds	Bureaux and Departments
SR	Security Regulations
ISIRT	Information Security Incident Response Team
DDoS	Distributed denial-of-service
GIRO	Government Information Security Incident Response Office
ICMP	Internet Control Message Protocol
TCP	Transmission Control Protocol
UDP	User Datagram Protocol

DNS	Domain Name System
HTTP	Hypertext Transfer Protocol
SSL	Secure Socket Layer
WAF	Web Application Firewall
CDN	Content Delivery Network
SOC	Security Operation Centre
IDPS	Intrusion Detection and Prevention System
SIEM	Security Information and Event Manager
BCP	Business Continuity Plan

1.4 Contacts

This document is produced and maintained by the Digital Policy Office (DPO). For comments or suggestions, please send to:

Email: it_security@digitalpolicy.gov.hk

Lotus Notes mail: IT Security Team/DPO/HKSARG@DPO

CMMP mail: IT Security Team/DPO

2. Why you need a mitigation strategy for DDoS attacks?

Distributed denial-of-service (DDoS) attacks have emerged as one of the most significant and prevalent threats on the security landscape. Any systems with exposure to the Internet are vulnerable to DDoS attacks. DDoS attacks could disruptively cost the victims in loss of services, productivity, revenue and reputation. Government bureaux/departments (B/Ds) need a mitigation strategy for DDoS attacks in order to bolster defenses and reduce the risk of attack. The strategy should include proactive planning, prevention, detection, and response and recovery measures. A DDoS mitigation strategy should not be aiming for the complete removal of all DDoS traffic but instead maintaining of services and especially critical services with minimum disruption. As individual B/D will have its specific environment and risks, each B/D should tailor the mitigation strategy according to its own requirement.

3. What are DDoS attacks?

DDoS attacks leverage bogus traffic from a multitude of attacking devices or botnets to overwhelm the target at a certain point in time, thereby incapacitating the target for delivering system or network resources. DDoS attacks are often described as volumetric, where the target is bombarded with more traffic than it can process.

There are two common types of DDoS attacks that an attacker leverages to exhaust system resources at the network and application level:

- (i) *Network-layer attack.* In network-layer attack, an attacker may attempt to consume the victim's network bandwidth by sending out significant amount of illegitimate traffic with a magnitude that outstrips the network capacity. Another way to launching the attack is to exploit the victim's server vulnerabilities to sap server resources such as memory until the services are knocked out. Network-layer attacks typically involve lining up thousands of compromised computers as a troop of bots (also known as botnet) that are commanded to inflict serious interruption on the network of targeted site. Legitimate users, while accessing the site hit by network service disruption, would therefore experience the site unresponsive or inaccessible.

The following table illustrates some possible types of DDoS attacks:

ICMP Flood	The Internet Control Message Protocol (ICMP) is a connectionless protocol used by hosts and routers to communicate network-level control information. An ICMP flood is an attack that sends a significant number of ICMP control messages to the target as fast as possible without waiting for replies. The target also attempts to respond with ICMP Echo reply. The attack consequently overwhelms both inbound and outbound bandwidth, resulting in denial of service.
Smurf Attack	A Smurf attack involves a perpetrator broadcasting every network nodes a malicious ICMP packet with the source address spoofed to the target's address. All network nodes that receive the ICMP packet send back a reply. The target receives a significant amount of replies, thus overwhelming the target's resources.
TCP SYN Flood	The Transmission Control Protocol (TCP) provides a connection-oriented transport service that allows for reliable data transmission. A TCP SYN flood works by establishing many half-open connections to a node for overwhelming target's resources. Half-open connection occurs when the client does not acknowledge the server with a SYN-ACK in order to complete the three-way handshaking.

UDP Flood	The User Datagram Protocol (UDP) is a connection-less, unreliable protocol that allows data to be exchanged without establishing a connection session. A UDP flood exploits the UDP protocol to initiate the attack. A perpetrator sends a target a high volume of UDP datagram specified with random port. The target needs to check for the application associated with that port. The checking is exhaustive, and the target becomes unresponsive when it continues to receive more and more UDP datagram.
-----------	---

- (ii) *Application-layer attack.* Application-layer attacks are rapidly evolved recently and develop into the most prevalent DDoS attacks nowadays. Instead of saturating network bandwidth or server resources, an intruder intends to bring down the victim's applications by striking against the weaknesses of their underlying application-layer protocol, for example Hypertext Transfer Protocol (HTTP) and Domain Name System (DNS). Unlike network-layer attack, application-layer attacks often masqueraded as legitimate traffic to evade captures. Initiating application-layer attacks also requires only minimal resources of an attacker to stealthily cause the target exhausted and down. This type of attack is thus considered as challenging to be nullified, constituting a real threat to the target. The following table illustrates some possible types of DDoS attacks:

DNS Amplification Attack	A DNS amplification attack consists of an attacker sending a Domain Name System (DNS) server a domain name lookup request with the source address spoofed to be the target's address. The DNS server, in turn, replies the target with a response that is significantly multiplied in size by containing as much zone information as possible. An attacker typically uses publically accessible open DNS servers to instigate the attack.
DNS Flood	A DNS flood attempts to consume the resources of a DNS server by sending a massive amount of domain name lookup requests to the server via either the attacker itself or the botnet. The DNS server eventually turns into overwhelmed and unable to respond of legitimate DNS requests.
HTTP Flood	The Hypertext Transfer Protocol (HTTP) is an application-layer protocol which allows the transfer of text, graphics, sound or movies over the World Wide Web via a hypertext interface of a web browser. A HTTP flood is a common application-level attack that targets to saturate the victim resources. In HTTP flood, multiple perpetrators, such as bots, simultaneously send a sheer volume of seemingly legitimate HTTP GET or POST requests to the targeted web server. This attempts to exhaust the resources of the web server, resulting to denial-of-service.

Low & Slow Attack	A Low & Slow attack exhausts application capacity with minimal resources. Attacker sends the target an apparently legitimate traffic at a relative slow rate over a period of time. It leaves the established connections open and keeps them from closing.
NTP Amplification Attack	A NTP amplification attack exploits the vulnerability of NTP server that allows administrators to query the traffic count of connected clients. An attacker attempts to request the traffic count from a NTP server. It causes the NTP server transmits a response, which is larger in size compared with the request, to the target machine instead due to the spoofed source address.
SSL Flood	The Secure Socket Layer (SSL) provides a means to encrypt data transmitting over a communication protocols. A SSL flood consumes available server resources by taking advantage of the asymmetric use of power by the client and server. The server fails to reply the legitimate user and results in crash when large amount of attacking machines keep negotiating SSL connection with the targeted server.

4. What are the mitigating measures?

DDoS threats can be properly managed through conducting a proactive planning and introducing appropriate preventive, detective, and response and recovery measures. A proactive planning is for identifying risks and vulnerabilities that are associated with DDoS attacks, as well as developing procedures and capabilities that are required for handling DDoS attacks. Preventive measures are for avoiding or deterring the occurrence of a DDoS attack. Detective measures are for identifying the occurrence of a DDoS attack. Response and recovery measures are for containing damages and restoring availability of information systems when a DDoS attack occurs. With prudent security controls and swift action, the impacts and costs of DDoS attacks could be effectively minimised.

4.1 Proactive Planning

- (i) Develop a Business Continuity Plan (BCP) and conduct regular drills to ensure sustainability of B/D's critical business processes during and after a DDoS attack.
- (ii) Perform security risk assessment of information systems at least once every two years to identify and evaluate security risk related to the use of information technology, and whenever possible, conduct vulnerability scanning and penetration testing to identify and remove vulnerabilities susceptible to DDoS attacks.
- (iii) Perform security audit periodically to ensure the compliance of IT security policies and effective implementation of security measures.
- (iv) Conduct capacity planning regularly to understand the demand of system and network resources as well as to devise the future plan by taking into account the utilisation growth and the additional resources for handling DDoS attacks.
- (v) Keep staff abreast of the emerging threats and the latest anti-DDoS techniques through regular security and awareness trainings.
- (vi) Remain vigilant against the impending security threats issued by DPO and those gathered by security intelligence.
- (vii) Ensure external contractors engaged in Government projects observe the security requirements stipulated in both Security Regulations (SR) and IT security policies.
- (viii) Include anti-DDoS requirements in the design and deployment phases of Internet-facing web applications.

4.2 Preventive Measures

- (i) Apply the latest security patches and updates released by product vendors to the operating systems and applications of the information systems to avoid DDoS attacks through known issues or vulnerabilities.
- (ii) Enable anti-malware solutions to detect and guard all endpoints and servers against computer viruses and malicious codes.
- (iii) Configure network devices properly with all unnecessary services or components removed or restricted, for example, blocking unnecessary ping traffic and requests from unauthorised network ports.
- (iv) Adopt Intrusion Detection and Prevention System (IDPS) to monitor anomalous activities in the network, analyse for signs of possible suspicious attack, and attempt to stop the abnormal activities.
- (v) Segregate the network so that critical and normal services can utilise different network connections.
- (vi) Apply network ingress filtering on the routers and firewalls to prevent an attacker from making use of spoofed and invalid source addresses to enter the network.
- (vii) Deploy the Web Application Firewall (WAF) to detect and block malicious payloads and specific types of attacks, such as SQL injection and cross-site scripting, by analysing every HTTP and HTTPS traffic.
- (viii) Consider leveraging Content Delivery Network (CDN) services offered by third-party security service providers to geographically distribute the network traffic and computer processing around the world.
- (ix) Consider utilising third-party managed DNS services to improve the DNS availability and to combat amplification attack.

4.3 Detective Measures

- (i) Implement visibility and control at the infrastructure level for continuous monitoring of the security status.
- (ii) Monitor the throughput of internal network and the usage of server resources, such as DNS and web server, to detect early traffic spikes and abnormal utilisation of system resources.
- (iii) Log and review security events and alerts generated by the security system, such as IDPS, anti-malware solution, Internet gateway, and firewall, to detect suspicious activities.
- (iv) Collect the logs of security events and store the logs in a centralized storage for log correlation and analysis as well as to prepare for forensic study in case of DDoS attacks.

4.4 Response and Recovery Measures

- (i) Report immediately suspected DDoS attacks case to the departmental Information Security Incident Response Team (ISIRT). ISIRT should then notify the Government Information Security Incident Response Office (GIRO) for the central recording and coordination support.
- (ii) Report the case, if suspected a computer crime has been committed, to the Technology Crime Division of the Hong Kong Police for conducting criminal investigation.
- (iii) Activate the incident response plan and, if necessary, the BCP to follow the established procedure for tackling the DDoS attack and restoring the system to normal operation.
- (iv) Preserve relevant log records for investigation.
- (v) Prepare a plan for handling public and media inquiries regarding the incident and disseminating relevant information to the public.
- (vi) Engage Internet Service Providers (ISPs) or security service providers in analysing and filtering attack traffic at the operation centre of the providers, where larger Internet traffic can be handled, in the event of DDoS attacks. Increase network resilience against DDoS attacks by applying load balancing and redundancy to distribute high volume of DDoS workload across multiple components and to allow immediate component replacement in case of component failure.
- (vii) Consider implementing black hole filtering to drop the attack traffic without noticing the source.

5. What anti-DDoS solutions are currently available?

Today, DDoS attacks have increased in sophistication and elusiveness. Traditional and standard network security solutions, such as firewall and IDPS, might not be sufficient to effectively and efficiently withstand the sophisticated DDoS attacks. B/Ds inevitably need to look for and acquire anti-DDoS solutions to strengthen the immunity to the emerging DDoS threats.

In general, common anti-DDoS solutions offered in the market exhibit the ability of multifaceted defences against both network-layer and application layer attacks. They implement with some advanced DDoS monitoring and mitigation technologies, like bandwidth throttling, CDN, managed DNS service, network behaviour analysis, traffic scrubbing, and WAF. The following gives a brief introduction to each of these technologies:

- (i) **Bandwidth Throttling.** Bandwidth throttling is a process to control and limit the bandwidth of a data connection for a particular client. It helps minimise network congestion and server crash.
- (ii) **Content Delivery Network (CDN).** A CDN comprises a large distributed system of servers deployed in multiple data centres across different geographic locations. It delivers web content to the client based on the client's geographic location, the origin of the web content, and also the available bandwidth of each node. It aims to achieve high availability and high performance.
- (iii) **Managed DNS Service.** A managed DNS service outsources the DNS service to a third-party service provider. It typically deploys globally and often rides on an anycast-enabled network to reduce network latency and to keep the availability high. The service can evade amplification attack by eliminating recursive caching function and adopting bandwidth throttling configuration.
- (iv) **Network Behaviour Analysis.** Network behaviour analysis compares current network traffic to the normal baseline, identifies abnormal traffic patterns and, based on continuous network traffic statistics, takes intelligent decision regarding attack mitigation.
- (v) **Network Ingress Filtering.** Network ingress filtering aims to defeat against denial-of service attack by prohibiting attackers from using forged source addresses which do not reside within a range of legitimately advertised prefixes.
- (vi) **Traffic Scrubbing.** Traffic Scrubbing centrally analyses the network traffic, filters the malicious one, and routes only the clean traffic to the network. It is a function normally carried out in a scrubbing centre. Traffic is redirected to the centre for cleansing prior to delivery when under DDoS attacks.

- (vii) **Web Application Firewall (WAF).** A WAF applies a set of rules to detect and thwart threats in the HTTP conversation. These rules also cover some common attacks such as SQL injection and cross-site scripting (XSS). In addition to traditional WAF approach, WAF comes with another two variants of deployment: cloud-based and distributed. A cloud-based WAF keeps the existing infrastructure unchanged and re-routes the web traffic to the WAF on the cloud, thus maximising the scalability and elasticity. A distributed WAF allows scattering the WAF components throughout an internal infrastructure, thus spreading the resources consumption across the network.

Further, auditing and reporting plays a crucial role in anti-DDoS solutions. Anti-DDoS solutions capable of handling auditing and reporting not only can gather, correlate and analyse real-time DDoS threat information, but also can offer advices and suggestions for counteracting those threats. They are also able to trigger necessary alerts and reports to make the attacks well-understood. Anti-DDoS solutions ought to exhibit the auditing and reporting capability to enable real-time analysis of the attack trend, informed decision about DDoS protection, and post-attack forensics.

The anti-DDoS solutions, possession of sophisticated DDoS protection technologies notwithstanding, need to accompany with security operation centre (SOC) staffed with a team of security expertise, in order to confront the frontline DDoS attacks round the clock. With the SOC, the supporting DDoS protection technologies can be swiftly adjusted to counteract rapid changes of DDoS attack patterns, hence keeping the defensive mechanism efficient.

Basically, anti-DDoS solutions are delivered in the form of appliance, cloud based service, or managed service. Anti-DDoS appliances are effective for the network-layer attack. They incur significant upfront expenditure for hardware and installation and recurrent cost for ongoing maintenance and in-house expertise. Alternatively, cloud-based and managed anti-DDoS services could be subscribed on-demand. They prevent DDoS attack traffic from infiltrating the target resources in front of the gateway of target network. The merits of these services are their flexibility, massive bandwidth and excellent visibility to the Internet traffic pattern.

6. What you need to consider when deploying anti-DDoS solutions?

B/Ds are advised to identify clearly the requirements for their anti-DDoS solution. The following selection criteria can be considered as reference during acquisition.

- (i) Ability to provide full coverage of multi-layer attacks. DDoS attackers usually target multiple vulnerability points of the IT infrastructure such as the network and application layers. The network layer is targeted with volumetric network flood attacks such as UDP flood, ICMP flood and TCP SYN flood. The application layer is targeted with a variety of attacks such as low and slow attacks, SSL flood and HTTP flood. The anti-DDoS solutions must be able to detect and mitigate attacks on all two layers.
- (ii) Ability to distinguish between DDoS attacker requests and legitimate user requests effectively. Anti-DDoS solutions should utilise advanced mitigation technologies in order to take intelligent decisions regarding the attack mitigation. For example, network behaviour analysis allows comparing current traffic to normal baselines.
- (iii) Ability to guarantee quality of experience to legitimate users even when the service is under DDoS attacks. To ensure sufficient resources for legitimate users, anti-DDoS solutions should allocate separate resources to combat DDoS attacks, without sharing them with processes for handling legitimate requests.
- (iv) Ability to protect the Internet pipe from saturation caused by volumetric attacks. Dealing with such attacks involves diverting attack traffic from premises into the cloud and mitigate the attack in the cloud. Thus these types of cloud-based anti-DDoS solutions need to demonstrate the ability to ensure smooth traffic transition to the cloud and maintain immediate mitigation.
- (v) Ability to integrate with existing Security Information and Event Manager (SIEM) that is able to aggregate, normalise, and correlate data from multiple sources. With the integration of SIEM, anti-DDoS solutions are capable of conducting real-time analysis and providing security reports that yield insight and trends about DDoS attacks in assisting with the attack mitigation.
- (vi) Availability of a 24x7 emergency response team, staffed with security professionals, to offer technical support during and after a DDoS attack. Possession of solid track records in dealing with DDoS events. Vendors of anti-DDoS solutions should demonstrate their expertise on providing anti-DDoS services, should receive positive comments from industry experts, and should be certified by recognised organisations.